

VULNERABILITY ASSESSMENT REPORT

Studente: Vincenzo Lembo

Corso: Cybersecurity & Ethical Hacking

Esercitazione: W12D1

Target: Metasploitable – 192.168.50.101

Scanner: Nessus

Scan Policy: Basic Network Scan

Port Range: Common Ports

Data scansione: 29/09/2026

1. Executive Summary

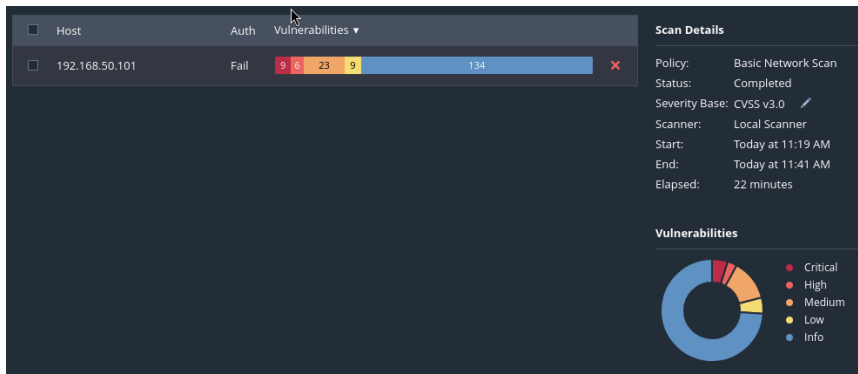
È stato eseguito un Vulnerability Assessment sull'host 192.168.50.101 mediante Nessus, con l'obiettivo di identificare vulnerabilità e configurazioni di sicurezza non adeguate presenti nei servizi esposti.

La scansione è stata configurata come **Basic Network Scan**, limitando il port scanning alle **Common Ports**.

L'analisi ha rilevato:

Severity	Findings
Critical	9
High	6
Medium	23
Low	9
Informational	134

I risultati evidenziano la presenza di vulnerabilità di diversa gravità, comprese vulnerabilità classificate come **Critical**, che richiederebbero interventi prioritari di remediation in un ambiente reale.



2. Scope e metodologia

2.1 Scope

L'assessment è stato effettuato sul seguente asset:

Asset	Indirizzo IP	Ruolo
Metasploitable	192.168.50.101	Target

2.2 Metodologia

L'analisi è stata effettuata utilizzando **Nessus** mediante una **Basic Network Scan**.

La fase di Discovery è stata configurata per effettuare il port scanning sulle **Common Ports**, mentre i parametri di Assessment e Advanced sono stati mantenuti ai valori predefiniti.

I finding sono stati classificati secondo la severity indicata da Nessus e i relativi punteggi CVSS.

3. Technical Findings

Nota sull'analisi dei finding

Considerato l'elevato numero di risultati prodotti dalla scansione, nel presente report vengono analizzati nel dettaglio i finding ritenuti maggiormente significativi e alcuni finding rappresentativi dei diversi livelli di severità. Il quadro complessivo dei risultati rilevati da Nessus è riportato nell'Executive Summary. I finding di tipo Informational non sono stati approfonditi singolarmente, in quanto principalmente finalizzati alla raccolta di informazioni sui servizi e sulla configurazione del sistema target.

● Finding 01 — Canonical Ubuntu Linux SEoL (8.04.x)

Campo	Valore
Severity	 Critical
CVSS v3.0	10.0
Affected Host	192.168.50.101
Affected Port	80/TCP
Service	HTTP/WWW
Nessus Plugin ID	201352

Descrizione tecnica

Nessus ha identificato sul target la presenza di **Ubuntu Linux 8.04**, versione che ha raggiunto il proprio *Security End of Life*.

Un sistema operativo che ha raggiunto la fine del supporto di sicurezza non riceve più le normali patch e gli aggiornamenti necessari alla correzione delle vulnerabilità scoperte successivamente.

Evidenza

Nessus ha identificato:

Ubuntu Linux 8.04

La versione risulta aver raggiunto il Security End of Life il **9 maggio 2013**.

Impatto

L'utilizzo di un sistema operativo non più supportato aumenta il rischio di compromissione dell'host, poiché vulnerabilità note o scoperte successivamente possono rimanere prive di patch di sicurezza.

Remediation

Migrare il sistema verso una versione del sistema operativo attualmente supportata e applicare gli aggiornamenti di sicurezza disponibili.

Priorità di intervento

Critica, in base alla classificazione fornita dallo scanner e al punteggio CVSS 10.0.

● Finding 02 — VNC Server 'password' Password

Campo	Valore
Severity	 Critical
CVSS v3.0	10.0
Affected Host	192.168.50.101
Affected Port	5900/TCP

Service VNC

Nessus Plugin ID 61708

Descrizione tecnica

Il server VNC in esecuzione sull'host remoto è protetto da una password debole. Nessus è riuscito ad autenticarsi tramite VNC utilizzando la password "**password**". Un attaccante remoto non autenticato potrebbe sfruttare questa vulnerabilità per **ottenere il controllo del sistema**.

Evidenza

Nessus è riuscito ad autenticarsi correttamente utilizzando la password debole "password".

Impatto

La presenza di una password VNC debole può consentire a un attaccante remoto di ottenere accesso al sistema. In caso di compromissione, l'attaccante potrebbe visualizzare e controllare il desktop remoto, accedere a informazioni presenti sul sistema ed eseguire operazioni con i privilegi dell'utente associato alla sessione VNC. Questo potrebbe compromettere la **confidenzialità, l'integrità e la disponibilità** del sistema

Remediation

Proteggere il servizio VNC utilizzando una password robusta.

Finding 03 — SSL Version 2 and 3 Protocol Detection

Campo	Valore
Severity	 Critical
CVSS v3.0	9.8

Affected Host 192.168.50.101

Affected Port 25/TCP 5432/TCP

Service smtp/postgresql

Nessus Plugin ID 20007

Descrizione tecnica

Il servizio remoto accetta connessioni cifrate tramite **SSL 2.0 e SSL 3.0**, versioni che presentano diverse vulnerabilità crittografiche. Tra queste figurano uno schema di padding non sicuro con i cifrari CBC e meccanismi inadeguati per la rinegoziazione e la ripresa delle sessioni. Un attaccante potrebbe sfruttare tali difetti per condurre attacchi **Man-in-the-Middle** o per **decifrare le comunicazioni** tra il servizio e i client. Sebbene SSL/TLS preveda un meccanismo per scegliere la versione più recente, molti browser lo implementano in modo non sicuro, consentendo un downgrade come nell'attacco **POODLE**. Per tale ragione, è opportuno **disabilitare completamente questi protocolli obsoleti**. Il **NIST** ha stabilito che SSL 3.0 non è più adeguato per comunicazioni sicure; inoltre, secondo lo standard **PCI DSS v3.1**, nessuna versione di SSL soddisfa la definizione di "**crittografia forte**" del PCI SSC.

Evidenza porta 25/TCP (SMTP)

SSLv2 is enabled and the server supports at least one cipher.

- Low Strength Ciphers (<= 64-bit key)

Evidenza porta 5432/TCP (POSTGRESQL)

- SSLv3 is enabled and the server supports at least one cipher.

- Explanation: TLS 1.0 and SSL 3.0 cipher suites may be used with SSLv3
- Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

Impatto

L'utilizzo di versioni obsolete di SSL e di suite crittografiche deboli riduce la sicurezza delle comunicazioni. Queste debolezze possono esporre il traffico ad attacchi di tipo Man-in-the-Middle e compromettere la riservatezza dei dati trasmessi.

Remediation

Disabilitare il supporto ai protocolli obsoleti **SSL 2.0 e SSL 3.0** sui servizi interessati, seguendo la documentazione delle applicazioni utilizzate. Configurare i servizi affinché utilizzino **TLS 1.2 o versioni successive**, adottando suite crittografiche considerate sicure.

Finding 04 — Apache Tomcat AJP Connector Request Injection (Ghostcat)

Campo	Valore
Severity	 Critical
CVSS v3.0	9.8
Affected Host	192.168.50.101
Affected Port	8009/TCP
Service	ajp13
Nessus Plugin ID	134862

Descrizione tecnica

È stata individuata una vulnerabilità di **lettura/inclusione di file** nel connettore **AJP**. Un attaccante remoto non autenticato potrebbe sfruttare questa vulnerabilità per **leggere i file dell'applicazione web** presenti sul server vulnerabile. Nei casi in cui il server vulnerabile consenta il caricamento di file, un attaccante potrebbe caricare **codice JavaServer Pages (JSP) malevolo**, incorporando in diverse tipologie di file, e ottenere così l'**esecuzione remota di codice (Remote Code Execution – RCE)** sul sistema.

Evidenza

Durante la scansione, Nessus è riuscito a sfruttare la vulnerabilità presente nel connettore **AJP** inviando una richiesta appositamente costruita al servizio vulnerabile.

Impatto

La vulnerabilità può consentire a un attaccante remoto non autenticato di accedere a file appartenenti all'applicazione web tramite il connettore AJP. In determinate configurazioni, in particolare quando è possibile caricare file sul server, la vulnerabilità può inoltre contribuire a scenari di **Remote Code Execution (RCE)**.

Remediation

Aggiornare **Apache Tomcat** a una versione corretta che risolva la vulnerabilità e verificare la configurazione del connettore AJP. Se AJP non è necessario, è consigliabile disabilitarlo; in caso contrario, limitarne l'accesso esclusivamente ai sistemi autorizzati e utilizzare le protezioni previste dalla versione di Tomcat installata.

Finding 05 — Critical Bind Shell Backdoor Detection

Campo	Valore
Severity	 Critical
CVSS v3.0	9.8
Affected Host	192.168.50.101
Affected Port	1524/TCP

Service wild_shell

Nessus Plugin ID 51988

Descrizione tecnica

Una shell è in ascolto sulla porta remota senza richiedere alcuna autenticazione. Un attaccante potrebbe sfruttarla collegandosi alla porta remota e inviando direttamente dei comandi

Evidenza

Nessus ha verificato concretamente la vulnerabilità eseguendo il comando:

- `id`

L'output ottenuto è:

- `uid=0(root) gid=0(root) groups=0(root)`

Questo risultato dimostra che il comando è stato eseguito con privilegi **root**, quindi con il massimo livello di privilegi sul sistema Linux.

Impatto

La vulnerabilità permette a un attaccante remoto di ottenere accesso alla shell del sistema senza autenticazione ed eseguire comandi con privilegi **root**. Ciò può comportare la compromissione completa del sistema, inclusi accesso ai dati, modifica dei file e controllo del server.

Remediation

Disabilitare immediatamente il servizio `wild_shell` sulla porta **1524/TCP** e impedire l'accesso alla porta tramite firewall. Verificare inoltre che non siano presenti altri servizi di shell remota non autenticati e utilizzare esclusivamente protocolli di amministrazione sicuri, autenticati e opportunamente configurati.

Finding 06 — Debian OpenSSH/OpenSSL Package Random Number Generator Weakness (SSL check)

Campo	Valore
Severity	 Critical
CVSS v2.0	10.0
Affected Host	192.168.50.101
Affected Port	5432/TCP 25/TCP
Service	postgresql / smtp
Nessus Plugin ID	32321

Descrizione tecnica

Il certificato **X.509** presente sul server SSL remoto è stato generato su un sistema **Debian o Ubuntu** affetto da un bug nel generatore di numeri casuali della libreria **OpenSSL**.

Il problema è dovuto alla rimozione, da parte di un manutentore del pacchetto Debian, di quasi tutte le fonti di **entropia** utilizzate dalla versione di OpenSSL interessata. Un attaccante potrebbe riuscire a ricavare la **chiave privata** associata alla chiave remota e utilizzarla per **decifrare le comunicazioni** oppure per effettuare un attacco di tipo **Man-in-the-Middle (MITM)**.

Evidenza

Per questo controllo, Nessus non ha registrato un output aggiuntivo da mostrare in questa sezione.

Impatto

La prevedibilità delle chiavi crittografiche può permettere a un attaccante di ricavare

la chiave privata e compromettere le comunicazioni protette. Questo può esporre i servizi interessati a intercettazione del traffico e attacchi **Man-in-the-Middle**.

Remediation

Tutto il materiale crittografico generato sul sistema vulnerabile deve essere considerato potenzialmente compromesso. È necessario **rigenerare le chiavi e i certificati** utilizzando una versione sicura e aggiornata della libreria OpenSSL.

In particolare, come indicato anche da Nessus, devono essere rigenerate eventuali chiavi **SSH, SSL/TLS e OpenVPN** prodotte sul sistema interessato.

Finding 07 — Debian OpenSSH/OpenSSL Package Random Number Generator Weakness

Campo	Valore
Severity	 Critical
CVSS v2.0	10.0
Affected Host	192.168.50.101
Affected Port	22/TCP
Service	SSH
Nessus Plugin ID	32314

Descrizione tecnica

La **chiave SSH dell'host remoto** è stata generata su un sistema **Debian o Ubuntu** affetto da un bug nel generatore di numeri casuali della libreria **OpenSSL**. Il problema è dovuto alla rimozione, da parte di un manutentore del pacchetto Debian, di quasi tutte le fonti di **entropia** utilizzate dalla versione di OpenSSL interessata. Un

attaccante potrebbe riuscire a ricavare la **chiave privata** associata alla chiave SSH del server e utilizzarla per **decifrare la sessione remota** oppure per effettuare un attacco di tipo **Man-in-the-Middle (MITM)**.

Evidenza

Per questo controllo, Nessus non ha registrato un output aggiuntivo da mostrare in questa sezione.

Impatto

La compromissione della chiave privata SSH può compromettere l'autenticità e la riservatezza delle comunicazioni con il server, esponendo le connessioni a possibili intercettazioni o attacchi Man-in-the-Middle.

Remediation

Le chiavi SSH generate con la versione vulnerabile di OpenSSL devono essere considerate non sicure. È necessario **rigenerare le chiavi SSH utilizzando una versione aggiornata e sicura di OpenSSL** e sostituire le vecchie chiavi.

Finding 08 — NFS Shares World Readable

Campo	Valore
Severity	 High
CVSS v3.0	7.5
Affected Host	192.168.50.101
Affected Port	2049/TCP
Service	rpc-nfs

Descrizione tecnica

Il server NFS remoto sta esportando una o più condivisioni senza applicare restrizioni di accesso basate sul nome host, sull'indirizzo IP o su un intervallo di indirizzi IP

Evidenza

Nell'output di Nessus viene riportato:

- The following shares have no access restrictions:
- / *

La presenza di * indica che la condivisione della directory **root (/)** non è limitata a uno specifico host o gruppo di host.

Impatto

Un host non autorizzato con accesso di rete al servizio NFS potrebbe tentare di montare la condivisione esposta e accedere ai file disponibili in base ai permessi configurati sul server. Poiché in questo caso viene esportata la directory /, l'esposizione è particolarmente significativa e potrebbe comportare accesso non autorizzato a dati del sistema.

Remediation

Configurare correttamente le esportazioni NFS applicando restrizioni agli host autorizzati. È consigliabile limitare l'accesso tramite **indirizzi IP o subnet specifiche**, evitando esportazioni accessibili tramite wildcard (*). È inoltre opportuno verificare la configurazione del file `/etc/exports` e applicare il principio del **minimo privilegio**, esponendo esclusivamente le directory effettivamente necessarie.

Finding 09 — Rlogin Service Detection

Campo	Valore
Severity	 High
CVSS v3.0	7.5
Affected Host	192.168.50.101
Affected Port	513/TCP
Service	rlogin
Nessus Plugin ID	10205

Descrizione tecnica

Il servizio **rlogin** è attivo sull'host remoto. Questo servizio è considerato vulnerabile poiché i dati scambiati tra il client e il server rlogin vengono trasmessi **in chiaro**, senza cifratura. Un attaccante in grado di effettuare un attacco **Man-in-the-Middle (MITM)** potrebbe intercettare il traffico e acquisire **credenziali di accesso, inclusi username e password**. Inoltre, il servizio potrebbe consentire, in presenza di configurazioni di autenticazione inadeguate, accessi senza password. Se l'host è vulnerabile alla previsione dei **numeri di sequenza TCP** o a tecniche di **IP spoofing**, incluso l'ARP hijacking all'interno di una rete locale, potrebbe essere possibile **aggirare i meccanismi di autenticazione**. Infine, rlogin può consentire di trasformare un accesso con permessi di scrittura sui file in un accesso completo al sistema attraverso una manipolazione impropria dei file **.rhosts** o **rhosts.equiv**.

Evidenza

La scansione Nessus ha identificato il servizio:

- 513/tcp - rlogin

sull'host:

- 192.168.50.101

Impatto

L'utilizzo di rlogin può esporre credenziali e altre informazioni sensibili all'intercettazione del traffico. Un attaccante posizionato sulla rete potrebbe sfruttare l'assenza di cifratura per effettuare attività di **sniffing** o tentare attacchi **Man-in-the-Middle**. Configurazioni rlogin non sicure possono inoltre consentire accessi non autorizzati al sistema.

Remediation

È consigliabile **disabilitare il servizio rlogin** e utilizzare **SSH** come alternativa sicura per l'accesso remoto, poiché SSH protegge le comunicazioni mediante cifratura. Nel sistema mostrato da Nessus, la remediation proposta consiste nel disabilitare la relativa configurazione in `/etc/inetd.conf` e riavviare il servizio `inetd`, oppure disabilitare completamente rlogin.

Finding 10 — Samba Badlock Vulnerability

Campo	Valore
Severity	 High
CVSS v3.0	7.5
Affected Host	192.168.50.101
Affected Port	445/TCP
Service	cifs
Nessus Plugin ID	90509

Descrizione tecnica

La versione di **Samba**, server CIFS/SMB per sistemi Linux e Unix, in esecuzione sull'host remoto è affetta da una vulnerabilità nota come **Badlock**. La vulnerabilità interessa i protocolli **Security Account Manager (SAM)** e **Local Security Authority – Domain Policy (LSAD)** ed è causata da una gestione non corretta della negoziazione del livello di autenticazione sui canali **Remote Procedure Call (RPC)**. Un attaccante in grado di effettuare un attacco **Man-in-the-Middle (MITM)** e di intercettare il traffico tra un client e un server che ospita un database SAM potrebbe sfruttare questa vulnerabilità per **forzare il downgrade del livello di autenticazione**. Ciò potrebbe consentire l'esecuzione di chiamate di rete Samba arbitrarie con i privilegi dell'utente intercettato, permettendo, ad esempio, di **visualizzare o modificare dati di sicurezza sensibili** presenti nel database **Active Directory (AD)** oppure di **disabilitare servizi critici**.

Evidenza

Nessus riporta:

- Nessus detected that the Samba Badlock patch has not been applied.

La vulnerabilità è stata individuata sul servizio:

- 445/tcp – cifs

Impatto

Lo sfruttamento della vulnerabilità può consentire a un attaccante in grado di intercettare il traffico di effettuare un downgrade dell'autenticazione RPC e operare nel contesto dell'utente intercettato. In determinati ambienti ciò può comportare l'accesso o la modifica di dati di sicurezza e l'interferenza con servizi Samba.

Remediation

Aggiornare Samba a una versione contenente la correzione per **CVE-2016-2118**. Nello specifico, Nessus indica l'aggiornamento a:

Samba 4.2.11 / 4.3.8 / 4.4.2 o versioni successive

Per un sistema reale, è comunque preferibile installare una **versione attualmente supportata e aggiornata di Samba**, anziché limitarsi alle vecchie versioni minime indicate dal plugin.

Finding 11 — Unencrypted Telnet Server

Campo	Valore
Severity	 Medium
CVSS v3.0	6.5
Affected Host	192.168.50.101
Affected Port	23/TCP
Service	telnet
Nessus Plugin ID	42263

Descrizione tecnica

L'host remoto esegue un server **Telnet** su un canale di comunicazione **non cifrato**. L'utilizzo di Telnet su un canale non cifrato è sconsigliato, poiché **credenziali di accesso, password e comandi vengono trasmessi in chiaro**. Ciò potrebbe consentire a un attaccante remoto, tramite un attacco **Man-in-the-Middle (MITM)**, di intercettare una sessione Telnet e ottenere credenziali o altre informazioni sensibili, nonché di modificare il traffico scambiato tra client e server. È preferibile utilizzare **SSH** al posto di Telnet, poiché SSH protegge le credenziali dall'intercettazione attraverso la cifratura delle comunicazioni e può inoltre essere utilizzato per veicolare in modo sicuro ulteriori flussi di dati, come una sessione **X11**.

Evidenza

Nessus ha identificato un server Telnet attivo sulla porta:

23/tcp – telnet

Impatto

L'utilizzo di Telnet può compromettere la riservatezza delle comunicazioni, poiché un

attaccante in grado di intercettare il traffico potrebbe acquisire credenziali, comandi o altre informazioni sensibili trasmesse durante la sessione.

Remediation

Disabilitare il servizio Telnet e utilizzare **SSH** come alternativa per l'accesso remoto, in modo da proteggere mediante cifratura le credenziali e il traffico scambiato tra client e server.

Finding 12 — SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Campo	Valore
Severity	 Low
CVSS v3.0	3.7
Affected Host	192.168.50.101
Affected Port	25/TCP
Service	smtp
Nessus Plugin ID	83875

Descrizione tecnica

L'host remoto consente connessioni **SSL/TLS** che utilizzano uno o più moduli **Diffie-Hellman** con una dimensione **inferiore o uguale a 1024 bit**. Attraverso tecniche di **crittoanalisi**, un attaccante potrebbe riuscire a determinare il segreto condiviso in un periodo di tempo relativamente breve, a seconda della dimensione del modulo utilizzato e delle risorse a sua disposizione. Lo sfruttamento di questa debolezza potrebbe consentire a un attaccante di **recuperare i dati trasmessi in**

chiaro (plaintext) o, potenzialmente, di **compromettere l'integrità delle comunicazioni**.

Evidenza

Nessus ha rilevato, tra le combinazioni vulnerabili:

- SSL/TLS version : SSLv3
- Cipher suite : TLS1_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
- Diffie-Hellman MODP size (bits) : 512
- Logjam attack difficulty : Easy (could be carried out by individuals)

L'evidenza mostra quindi l'utilizzo di un modulo Diffie-Hellman di soli **512 bit**.

Impatto

Una configurazione Diffie-Hellman con parametri crittografici deboli può ridurre la sicurezza delle connessioni cifrate. Un attaccante con capacità adeguate potrebbe sfruttare la debolezza dello scambio di chiavi per compromettere la riservatezza delle comunicazioni.

Remediation

Riconfigurare il servizio affinché utilizzi **moduli Diffie-Hellman univoci di almeno 2048 bit**, eliminando le configurazioni crittografiche deboli.

4. Tabella riepilogativa dei finding analizzati

ID	Finding	Severity	Porta
F01	Canonical Ubuntu Linux SEoL	Critical	80/TCP
F02	VNC Server 'password' Password	Critical	5900/TCP
F03	SSL Version 2 and 3 Protocol Detection	Critical	25, 5432/TCP
F04	Apache Tomcat Ghostcat	Critical	8009/TCP

F05	Bind Shell Backdoor Detection	Critical	1524/TCP
F06	OpenSSL RNG Weakness – SSL	Critical	25, 5432/TCP
F07	OpenSSL RNG Weakness – SSH	Critical	22/TCP
F08	NFS Shares World Readable	High	2049/TCP
F09	Rlogin Service Detection	High	513/TCP
F10	Samba Badlock Vulnerability	High	445/TCP
F11	Unencrypted Telnet Server	Medium	23/TCP
F12	SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits	Low	25/TCP

5. Conclusioni

Il Vulnerability Assessment eseguito sull'host Metasploitable **192.168.50.101** ha evidenziato la presenza di numerose vulnerabilità e configurazioni di sicurezza non adeguate, distribuite su differenti livelli di severità. Tra le problematiche più rilevanti sono state individuate la presenza di un sistema operativo non più supportato, credenziali VNC deboli, protocolli SSL obsoleti, vulnerabilità nel connettore AJP di Apache Tomcat e una bind shell accessibile senza autenticazione. In quest'ultimo caso, Nessus ha verificato l'esecuzione di comandi con privilegi **root**, evidenziando un rischio

di compromissione completa del sistema. Sono stati inoltre identificati servizi e configurazioni non sicure, tra cui condivisioni NFS prive di adeguate restrizioni, i servizi rlogin e Telnet con comunicazioni non cifrate, una versione di Samba vulnerabile a Badlock e configurazioni crittografiche basate su parametri Diffie-Hellman deboli. In un ambiente reale, le attività di remediation dovrebbero prevedere prioritariamente la rimozione o mitigazione delle vulnerabilità critiche, l'aggiornamento dei sistemi e dei servizi obsoleti, la disabilitazione dei protocolli non sicuri e l'applicazione di configurazioni di accesso e crittografia più robuste. L'attività ha permesso di utilizzare Nessus per individuare, classificare e analizzare vulnerabilità presenti su un sistema target, interpretando le evidenze prodotte dallo scanner e individuando per ciascun finding le relative misure di remediation.

Vincenzo Lembo